

Reconnaissance & Fingerprinting Report

Module 1: Passive & Active Web Infrastructure Intelligence

TARGET DOMAIN	PRIMARY IP	INFRASTRUCTURE	EXECUTION ENVIRONMENT
networkwalks.com	192.232.216.135	HostGator / Newfold	Linux (VirtualBox)

1. Executive Summary

This report provides a structured technical breakdown of the initial reconnaissance and fingerprinting phase conducted against `networkwalks.com`. The objective was to map public registrars, underlying server daemons, content management systems, security filters (WAF), and authoritative DNS records using industry-standard utilities: `whois`, `whatweb`, `nslookup`, `curl`, `wafw00f`, and `dnsrecon`.

The assessment revealed a WordPress-powered website hosted on an Apache backend fronted by an Nginx reverse caching layer. Active layer-7 filtering is enforced by a ModSecurity Web Application Firewall. Defensive deficiencies identified include disclosed software version numbers (BIND DNS and Apache), disabled DNSSEC, unsegmented mail/web hosting, and omitted HTTP security headers (HSTS, CSP, and framing protection).

2. Detailed Task Breakdown & Findings

Task 1: Domain Registration Intelligence

`whois`

- **Registrar:** GoDaddy.com, LLC (IANA ID: 146)
- **Registration Dates:** Created November 06, 2019 | Registry Expiry November 06, 2027 (Updated Nov 2025)
- **Domain Status:** `clientTransferProhibited`, `clientUpdateProhibited`, `clientRenewProhibited`, `clientDeleteProhibited`
- **Registrant Details:** Shielded via privacy proxy (`Domains By Proxy, LLC`, Tempe, AZ)
- **DNSSEC:** Unsigned

Technical Analysis: The domain is well-established (registered 2019), ruling out newly registered disposable attack infrastructure. The registrant utilizes identity masking, while registry lock flags mitigate unauthorized domain transfer risks.

[Attach Screenshot: `whois networkwalks.com` execution output]

Task 2: Web Technology Stack Fingerprinting

whatweb

- **CMS & Frameworks:** WordPress, Bootstrap, HTML5, jQuery v3.7.1
- **Detected Plugins:** *WordPress Download Manager (v3.3.58)*, *Really Simple Security*
- **Server Stack:** Apache (Origin) fronted by Nginx caching layer (`X-nginx-cache: WordPress`)
- **Identified Endpoints:** WordPress REST API (`/wp-json/`), public support email (`info@networkwalks.com`)
- **Cookie Configuration:** `__wpdm_client` with `HttpOnly` and `Secure` flags applied

Technical Analysis: The site explicitly discloses its CMS and exposes plugin versions via meta generators. Exposing the WP REST API allows targeted user and taxonomy enumeration.

[Attach Screenshot: `whatweb -v networkwalks.com` execution output]

Task 3: IP Address & DNS Resolution

nslookup

- **Queried Resolver:** `127.0.0.53#53` (Local Linux caching stub resolver)
- **Resolved IPv4 (A Record):** `192.232.216.135`
- **IPv6 (AAAA Record):** None configured (`NXDOMAIN` returned)
- **Autonomous System:** AS46606 (HostGator / Newfold Digital)

Technical Analysis: The host operates exclusively over IPv4. The resolver returned an expected `NXDOMAIN` when failing over to query IPv6 AAAA records.

[Attach Screenshot: `nslookup networkwalks.com` execution output]

Task 4: HTTP Response Header Hardening

curl -I

- **Protocol Negotiated:** HTTP/2 200
- **Server Header:** Server: Apache (Explicit software banner disclosure)
- **Reverse Proxy Caching:** x-nginx-cache: WordPress , x-endurance-cache-level: 0
- **Referrer-Policy:** no-referrer-when-downgrade

Security Header	Status	Security Implication
Strict-Transport-Security	Missing	Susceptible to man-in-the-middle SSL-stripping attacks.
X-Frame-Options	Missing	Leaves the application vulnerable to UI redressing (Clickjacking).
Content-Security-Policy	Missing	Fails to restrict script execution domains in the event of XSS.
X-Content-Type-Options	Missing	Enables MIME-sniffing behavior across legacy client browsers.

[Attach Screenshot: curl -I https://networkwalks.com execution output]

Task 5: Web Application Firewall Detection

wafw00f

- **Detected WAF:** ModSecurity (SpiderLabs)
- **Probing Requests:** 2 HTTP requests issued
- **Implementation:** Integrated within the Apache web tier via cPanel hosting management

Technical Analysis: ModSecurity inspects inbound HTTP requests against OWASP Core Rule Sets. Standard exploit payloads (SQLi, XSS) will trigger automated 403 Forbidden responses.

[Attach Screenshot: wafw00f https://networkwalks.com execution output]

Task 6: Comprehensive DNS Enumeration

dnsrecon

- **Authoritative Nameservers:** ns6135.hostgator.com (50.87.144.87) & ns6136.hostgator.com (192.232.216.131)
- **DNS Daemon Leakage:** Bind Version disclosed as "9.16.23-RH"
- **Mail Exchange (MX):** mail.networkwalks.com resolving directly to web root (192.232.216.135)
- **Sender Policy Framework (SPF):** v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all
- **SRV Autodiscovery:** 8 cPanel autodiscover records mapping to cpanelemaildiscovery.cpanel.net:443

Technical Analysis: The nameservers disclose their exact BIND package version. Web and mail services share identical IP space, creating an operational single-point-of-failure.

[Attach Screenshot: dnsrecon -d networkwalks.com -t std execution output]

3. Remediation & Hardening Roadmap

Severity	Observed Finding	Operational Impact	Remediation Guidance
Medium	Missing Defensive HTTP Headers	Clients lack enforcement for TLS downgrades and clickjacking protection.	Enforce Strict-Transport-Security: max-age=31536000; includeSubDomains , X-Frame-Options: SAMEORIGIN , and baseline CSP rules.
Low	Software Version Disclosure	Direct exposure of Apache server headers and BIND 9.16.23-RH daemon versions.	Set ServerTokens Prod and ServerSignature Off in Apache; configure version "none"; in named.conf .
Low	Disabled DNSSEC	Zone responses are unauthenticated and prone to spoofing / cache poisoning.	Generate cryptographic keys (KSK/ ZSK) and configure DS records at the domain registrar.
Low	Co-located Mail & Web Hosting	Web layer exhaustion directly disrupts SMTP mail service.	Migrate MX handling to isolated external mail infrastructure or segregated subnets.
Info	SoftFail SPF Implementation	~all flag allows downstream MTAs to accept spoofed emails with relaxed penalties.	Transition SPF directive from ~all to -all (HardFail) and pair with DKIM and DMARC enforcement.